



Strengthening Board Oversight of AI – The A.I. GUARD Framework

Authors:

Mahi Dontamsetti

Jim Routh

Strengthening Board Oversight of AI – The A.I. GUARD Framework

October 2025

- Authored by Mahi Dontamsetti and Jim Routh

Copyright 2025 Mahi Dontamsetti and Jim Routh. All rights reserved.

This white paper is protected by copyright law. No part of this publication may be reproduced, distributed, or transmitted in any form or by any means, including photocopying, recording, or other electronic or mechanical methods, without the prior written permission of the authors, except in the case of brief quotations embodied in critical reviews and certain other noncommercial uses permitted by copyright law.

Executive Summary

Artificial Intelligence (AI) presents both unprecedented opportunities and complex risks for corporations. For boards of directors-particularly those in Fortune 1000 firms the challenge is no longer if AI oversight is necessary, but how to effectively oversee AI efforts across the enterprise while realizing business benefits.

This paper introduces the A.I. GUARD Framework, a practical and strategic governance model designed to empower boards in their fiduciary role over AI initiatives. Leveraging over 4 decades of combined authors' experience in board interactions, it outlines seven foundational steps boards can adopt to ensure responsible AI development, deployment, and monitoring, while maintaining regulatory readiness and public trust.

The Growing Imperative for Board-Level AI Oversight

AI now changes critical areas such as decision-making, risk modeling, cybersecurity, customer engagement, data integrity and operational efficiency. However, unchecked AI systems will introduce bias, privacy violations, security vulnerabilities, and reputational damage.

Board members are increasingly expected to not only understand AI but to ensure oversight with the same rigor as financial, operational, and risk management. However, this requirement for board members must be take into account the current challenges associated with serving on a company's board.

The role of a board member, especially in public companies, is becoming increasingly complex. In addition to traditional responsibilities such as strategy, investments, M&A, performance management, risk, audit, talent, and CEO succession planning, new issues like cyber security, resilience, and geopolitics are regularly added. These additions do not replace existing accountabilities, resulting in more extensive meeting materials, often over 500 pages, and increased meeting frequency beyond the traditional quarterly schedule. This expanded scope and higher engagement levels make the role of a board member more demanding.

Adding to this complexity, there is the new demand for boards to oversee Artificial Intelligence (AI) efforts at their firms, likely the most transformative technology of our times. AI (generative AI or large language models) has the potential to radically transform industries, upend traditional thinking, bring huge benefits and increased risks to firms. Successfully guiding a firm through this journey is now the call of the hour for most boards.

From a board's perspective, board directors need to understand how effectively their firm is dealing with the challenges and opportunities of Artificial Intelligence (AI), and how the firm defines AI programs, and accountable executives for overall AI success.

AI is disrupting the way we work, and board directors need to understand how AI can potentially disrupt a firm's business. Regulatory changes are also impacting boards' obligations with respect to their understanding and knowledge of AI. Boards need to be more conversant with AI's regulatory, privacy and compliance risks. Board members should have a healthy skepticism of management and to fulfill their oversight role need to be well-versed in AI to be able to challenge management effectively. This view is also shared by Chris Hetner, former Cybersecurity Advisor to 2 SEC Chairs and Cyber Risk Advisor to the National Association of Corporate Directors who says, "It is essential for boards to continuously incorporate cyber and AI risk management discussions related to the most effective way to reduce the financial and business impact connected with these risk domains. The conversation isn't just for the Chief Information Officer (CIO) and Chief Information Security Officer (CISO). It is a broader c-suite discussion, in which the Chief Financial Officer (CFO), General Counsel and Head of Compliance must participate"

When individuals interact with large language models (LLMs) through a query or prompt, the results often surprise users with innate understanding and comprehensiveness. However, it's essential to understand that LLMs operate by determining the probability of word sequences based on the dataset they were trained on. While machine learning systems like LLMs are deterministic, meaning they produce the same output for the same input every time, the responses generated by LLMs are inherently stochastic. This means that the output may vary even for the same prompt, and the accuracy of the response cannot be guaranteed every time.

The accuracy and reliability of business processes depend heavily on the quality of the data used to inform decision-making. However, the potential for errors or inaccuracies in large language models (LLMs) can have significant and far-reaching consequences for customers and business outcomes. Specifically, the risk of "hallucinations" - where an LLM generates information that is not supported by the data or is entirely fictional - can be particularly problematic.

The term "hallucination" in this context refers to a phenomenon where an LLM generates text that is not grounded in reality, often due to the model's ability to fill gaps in its understanding of a topic or its tendency to make educated guesses. This can have serious consequences, including misleading customers, compromising business decisions, or even perpetuating misinformation.

As a result, board members need a set of guiding principles to ensure effective management oversight as they navigate the challenges and opportunities presented by large language models. These principles can help organizations mitigate the risks associated with LLMs and ensure that they are used responsibly and to their full potential.

The A.I. GUARD Framework provides these principles for board members.

Introducing the A.I. GUARD Framework

The A.I. GUARD Framework outlines seven principles to help boards enhance their AI oversight. These principles were created with current board responsibilities in mind, requiring minimal extra effort. Adopting them will help boards oversee AI effectively and communicate the company's AI strategy, risk appetite and on-going AI efforts to regulators, investors, and stakeholders. The framework is based on adaptable principles rather than strict rules, allowing firms to customize it and integrate it easily into existing systems.

A - Advance Board Understanding and Expertise in AI

AI is strategic and its impact is enterprise wide. Boards need to review their committee charters, structure, and expertise to get assurance that AI is managed as a strategic imperative at the board level. Effective oversight requires understanding of AI fundamentals, risks, and emerging trends requiring investment by board members in director level AI education and potentially supplementing the board with new directors with relevant experience.

I - Integrated AI Governance Framework

An integrated AI governance framework ensures that both the board and management treat AI as a strategic priority. A comprehensive governance structure, integrated with the existing frameworks of the firm, should define how AI initiatives are proposed, evaluated, implemented, managed, and monitored. This framework should incorporate ethical considerations, business strategy, and enterprise risk management.

G - Governance with clearly defined Accountability & Authority

Boards should ensure that management has clearly defined roles and responsibilities for AI decision-making. As highlighted earlier, many AI initiatives fail due to fragmented responsibilities and unclear decision-making processes. The board should require transparency regarding who is accountable for the development, testing, deployment, management, and overall success or failure of AI systems.

U - Understanding of Risk Appetite and Reporting across Enterprise

Boards should approve an AI risk appetite statement and risk reporting. Since AI risks are emerging and unpredictable, staff may inadvertently create risk. Boards should ensure that management clearly communicates the AI risk appetite statement and metrics within the firm, so they are understood and help guide those making risk decisions.

A - Accelerate Continuous Learning and Improvement

Boards should expect management to foster a culture of continuous learning and improvement. Management should promote AI-driven innovation, honest post-mortems, and insightful learning from failures and successes. Continuous improvement should be integrated into technical and governance processes.

R - Respond to Incidents with Structure, Process and Protocols

Boards must receive assurances from management that adequate structures, processes, and protocols are established by management for incident reporting and escalation in relation to AI failures, breaches, or unintended outcomes.

D - Disclose with Regulatory Readiness

Regulators hold the board accountable for overseeing AI risk management. The board must not only understand but be able to confidently communicate management's actions to regulators. Management should ensure AI disclosures are clear and comply with SEC, FTC, and international guidelines.

Generative AI Primer

Business enterprises have been deploying machine learning systems successfully within core business processes for decades. These systems go through in-depth testing and assurance practice to produce consistent and accurate results. These models are often referred to as deterministic models meaning they produce the same output or results consistently based on the source data. In other words, they are applied to determine the correct output. Many core business processes supporting customers day in and day out are dependent on the results of deterministic models.

Large Language Models (LLMs) work by processing text as a sequence of tokens, which can be individual words, sub words (smaller units of words), or even characters. Unfortunately, not all the data in a selected data set will be accurate. Sometimes, query results will be added to the data set and potentially degrade the quality of data over time. LLMs don't use reasoning to calculate results, they use probability retrieving tokens that are translated into words.

Data scientists understand the difference between deterministic and stochastic models along with the operational implications of using LLMs with business processes anticipating a deterministic result. Data scientists are working to improve the accuracy of LLMs using reinforcement learning model's additive to an LLM designed to increase the accuracy of the result.

As an example, if an LLM data set is created using data of medical practices historically and a prompt is entered using two words: medical and male, the LLM output will be

doctor. A second prompt of medical and female will produce the output, nurse. ¹The LLM is producing the result based on the probability of doctor for the male and nurse for the female given the historical data. However, these results are biased and should not be applied as necessarily accurate in the future. Humans immediately see bias in the results but LLMs cannot. Broad usage of LLMs across enterprises creates ethical challenges that often need human judgment.

Here's a high-level overview of the process:

1. **Tokenization:** The input text is broken down into individual tokens, which are then fed into the model. This can be done at the word level, sub word level, or even character level.
2. **Embeddings:** Each token is converted into a numerical vector representation, called an embedding. These embeddings capture the semantic meaning and context of the token.
3. **Sequence modeling:** The model processes the sequence of tokens one at a time, using a technique called self-attention. This allows the model to weigh the importance of different tokens in the sequence and consider their relationships.
4. **Probability calculation:** The model calculates the probability of each token following the previous token(s) in the sequence. This is typically done using a SoftMax function, which outputs a probability distribution over all possible next tokens.
5. **Sampling:** The model samples from the probability distribution to generate the next token in the sequence. This process is repeated for each token in the input sequence.

The key idea behind LLMs is to learn the probability distributions over token sequences, rather than focusing on individual tokens. This allows the model to capture complex patterns and relationships in language, such as context, syntax, and semantics.²

Business processes within corporations are changing daily with the help of models and this is changing the way employees work. LLMs are accelerating the change to how employees and contractors do their work. In many cases, categories of workers are no longer essential for tasks like conducting research, writing software programs, creating spreadsheets, producing media for marketing, etc. Board members need to understand

whether management is recognizing and applying ethical judgment in the use of LLMs on behalf of customers, employees, stakeholders, and shareholders.

The A.I. GUARD framework will enhance the board's oversight of AI initiatives, benefiting the enterprise by helping management consider and integrate all risks into their people, process, and technology.

Growing Imperative for Strengthening AI Board Oversight

Recent market and industry surveys validate the need for the Board of Directors to strengthen AI board oversight.

- According to McKinsey³ over 45% of firms in their survey indicated GenAI is owned by the Board of Directors/CEO. For these firms there is a strong correlation with a positive bottom-line impact compared to firms where GenAI is not owned by BoD/CEO.
- Another report from IBM⁴ indicates only 8% of banks were developing generative AI systematically in 2024, and 78% had a tactical approach. This indicates a lack of expectation set from the board to management that AI is strategic
- A recent Fortune magazine Survey⁵ on “How are CEOs actually thinking about AI” indicate 74% of CEOs overall – and 79% in the U.S. – said they would lose their jobs within two years if they don’t deliver measurable AI-driven business gains. Furthermore 70% of CEOs said they believe a fellow CEO will be ousted by year’s end due to a failed AI strategy or AI-induced crisis
- An MIT⁶ report “The GenAI Divide – State of AI in Business 2025” finds that “Despite \$30–40 billion in enterprise investment into GenAI, this report uncovers a surprising result in that 95% of organizations are getting zero return”. It further goes on to state that, “This divide does not seem to be driven by model quality or regulation but seems to be determined by approach”
- A Recent National Association of Corporate Directors (NACD) paper⁷ on “Implementing AI Governance” notes that while many directors note the potential for AI disruption of their company’s current strategy and long-term viability, only 23% of the boards have assessed how this disruption might happen or where it might come from
- The challenge is not the lack of initiatives; anecdotal evidence from discussions with Fortune 500 AI council chairs reveals a plethora of pilots and proof-of-concepts. However, the transition from pilot to production remains limited, often due to the absence of a comprehensive framework, resulting in wasted resources and AI fatigue. This underscores the increasing opportunity costs of missing out

on tangible AI benefits.

- AI is a strategic risk impacting several risk domains. AI initiatives have a cross-domain impact across domains such as cybersecurity, privacy, legal, compliance, IT, third party management, business and corporate functions as well as across geographies and regulatory jurisdictions.
- Corporate functions, whose natural bias is to focus on downside risk since they are accountable if risks manifest but do not typically share in any upside from AI initiatives may be overly conservative and require acknowledgment of potential risks and acceptance at the CEO/Board level.

The above reinforces the fact that boards need to acknowledge that there will be tremendous tension in management between the need for delivering AI driven wins expeditiously and the need to ensure those wins are not coming at the expense of shortchanging the various AI risks. Boards need to strengthen oversight to ensure management is striking the right balance between driving AI fueled innovation while ensuring risks arising from AI adoption are being managed.

Benefits of Board Oversight:

- Involvement at the Board level signals the importance and criticality of AI initiatives to the entire firm.
- While other initiatives like major transformations, M&A, and divestitures share some aspects of AI rollout, few have the same strategic importance, reputational impact, regulatory focus, and galvanizing effect on employees and clients.
- Board-level involvement also will drive urgency and adoption, leading to success. There is often a reverse Heisenberg principle effect, the more the board focuses on a particular area, the better it typically becomes because management is hesitant to report lack of progress on board focus areas.
- It helps with resource contention and speeds up internal approvals. Firms often identify new high-priority projects but are notorious for failing to deprioritize others, leading to delays and overburdening of staff. Clearly identifying a project as a Board priority cuts through internal bureaucracy and red tape.
- Send a very positive message to key external stakeholders such as regulators, investors, clients and suppliers.

Strengthening Board Oversight of AI – Introducing A.I. GUARD Approach

We believe the following seven principles are core to strengthening board oversight of AI. These principles should drive the assurances and expectations from management that boards should demand to be able to fulfill their AI oversight function effectively.

A - Advance Board Understanding and Expertise in AI

1. AI is a strategic risk

Boards need to recognize that AI is strategic and should be an integral part of all major transformations a firm is undertaking to effectively compete in this new AI age. It is not limited to specific functional domains but spans across the enterprise, impacts the whole firm and its competitive posture.

The afore mentioned Fortune article on CEO survey⁵ and concerns from CEO's losing their jobs tied to lack of AI progress reinforce the fact that boards need to acknowledge that there will be tremendous tension in management between the need for delivering AI driven wins – expeditiously and the need to ensure those wins are not coming at the expense of shortchanging the various AI risks such as cyber, privacy, regulatory etc. A key board AI oversight imperative is ensuring management is striking the right balance between driving AI fueled innovation while ensuring risks arising from AI adoption are being managed. The key questions board members need to ask are how will AI be leveraged by management to fundamentally transform the business while ensuring AI risks are being expeditiously identified, holistically assessed and prudently managed.

To be able to fulfill their oversight function boards need to first ensure they have sufficient understanding and AI relevant expertise. Firms typically have multiple committees – Audit committee, risk committee, technology & operations committee etc. The nominating and governance committee of the board needs to review the various committee charters to ensure there is clear understanding of how AI will be overseen by the board and to avoid redundant efforts. Decisions should be made if AI will be discussed at an individual committee level with summaries presented by that committee chair to the entire board or if AI should be discussed at the full board. If an individual committee level approach is chosen, committee membership should be reviewed and modified if necessary to ensure appropriate board expertise exists in that committee. AI should be a key element of any new incoming directors' on-boarding package along with dedicated meetings with key executives driving AI efforts in the firm. Recent

NACD paper⁷ has some good guidance on this topic.

If a need for augmenting board expertise in AI is determined, it needs to proactively take actions to address that gap. It can do it in several ways:

- Institute separate deep dive AI sessions as part of regular board meeting cadence. These sessions should include outside industry experts as well as management deep dives on AI initiatives. Often these meetings are not recorded and provide a venue for both the board members and management to have frank open discussions. Board members who might be reticent to ask basic AI questions that might indicate lack of knowledge in a formal board meeting will often be open to asking probing questions in such sessions resulting in overall understanding and an increase in AI expertise amongst the board.
- Have an outside consulting firm conduct a formal comprehensive AI programmatic review of the firm's AI efforts and provide a detailed independent report to the board with a formal readout in a board meeting. Often these firms are engaged to periodically review management progress at a set cadence.
- Add an AI industry expert to the board. This is typically done in areas where the knowledge required is very specialized. For instance, in the case of Cyber, boards are known to bring in Cyber experts (sometimes folks who have had Government clearances) from either the Government, Industry, Cloud Services Providers (CSPs), Security vendors etc. However, this approach needs to be tempered with the fact that having an "AI expert" on the board does not dilute rest of the boards responsibility to understand AI since it is a strategic risk.

2. Firm Specific AI Risks

Boards should review the firm's current risk taxonomy and have management explain how AI will impact it. Specifically:

- i. Ask what new risks will be added to the corporate risk taxonomy due to AI adoption and why?
- ii. Which existing risks in the risk taxonomy will be exacerbated due to AI adoption and how? Will the impact be higher or would the likelihood of occurrence increase?
- iii. Are there instances where existing risks will be reduced because of AI adoption? Will the impact be reduced or the likelihood decrease?
- iv. Given AI is a fast-evolving area, would our traditional risk taxonomy refresh processes suffice, or would we need to implement a more frequent risk taxonomy update mechanism?

- v. Do we have the people, process and technology to expeditiously identify, holistically assess and prudently manage these new risks?

I – Integrated AI Governance framework

Boards should seek assurances that management is adopting a comprehensive governance framework that defines how AI initiatives are proposed, evaluated, implemented, managed and monitored. This framework should integrate ethical considerations, business strategy, and enterprise risk management. There are several very good frameworks widely adopted by industry. Few are highlighted below.

Regulatory Frameworks

1. **NIST AI Risk Management Framework⁸**: This framework provides a comprehensive approach to managing risks associated with AI systems. It emphasizes trustworthiness, risk management, and voluntary use.
2. **Singapore's Model AI Governance Framework⁹**: This framework offers a set of principles and guidelines for the ethical and responsible use of AI, focusing on transparency, explainability, and accountability.
3. **EU AI Act¹⁰**: Is a regulation that sets rules for the development, deployment, and use of artificial intelligence in the European Union. It aims to promote trustworthy and human-centric AI while ensuring a high level of protection for health, safety, fundamental rights, democracy, the rule of law, and environmental protection.

Industry Frameworks

1. **Google's Secure AI Framework (SAIF)¹¹**: A conceptual framework for securing AI systems. Address concerns such as Security, AI/ML Model Risk Management, Privacy and Compliance, People and Organization.
2. **Microsoft's Responsible AI Standard¹²**: A framework to guide how to build AI systems that are fair, reliable, safe, secure, transparent, and inclusive.
3. **Gartner AI TRisM¹³**: A comprehensive AI trust, risk, security management program to ensure AI systems are compliant, fair, reliable and protect data privacy
4. **ISO/IEC 42001¹⁴**: An international standard that specifies requirements for establishing, implementing, maintaining, and continually improving an Artificial Intelligence Management System (AIMS) within organizations. It is designed for entities providing or utilizing AI-based products or services, ensuring responsible development and use of AI systems.

Boards should assess if the AI framework chosen by management is well integrated with the rest of the firm's processes and enterprise frameworks and not a standalone be-spoke framework that is not aligned with how the firm operates on a day-to-day basis. In the long run, the choice of a particular framework is not as important as wide, deep and integrated adoption of a chosen framework. The chosen framework's approach, terminology, risks should get deeply embedded within an organization and become the lingua franca for all AI initiatives.

Relevant AI related reporting, including to the board of directors, should adopt the chosen frameworks terminology, risk rating methodology, categorization, and governance principles. These frameworks are also a good starting point for management to determine the impact to existing corporate risk taxonomy and required changes that need to be made.

G – Governance with clearly defined Accountability & Authority

Boards should have expectations that management has clearly defined roles and responsibilities for AI decision-making. The board should demand transparency on who is accountable for the development, testing, deployment, and management of AI systems. Best practice has shown that most mature firms rather than distributing AI accountability by functional ownership (CIO for IT, CISO for security, Chief Privacy Officer for privacy etc.) identify a single or at most two leaders who are designated DRIs (Directly Responsible Individuals) that have ownership for all AI initiatives across the firm.

It is imperative that boards not only hold those executives accountable for adoption and success of AI initiatives, but they also need to assist in providing them with the relevant authority to make decisions. This is often a challenge for organizations who are quick to hold executives accountable but are poor at providing them with the authority to make key decisions. This happens because of an inherent in-built conflict that arises across functions. If every control function, such as CISO, Chief Privacy Officer, Legal, Compliance, Risk, Architecture etc. has veto rights or individual approvals are required, AI initiatives get throttled. Senior executives, often CEO direct reports leading AI initiatives, help overcome these conflicts since they have a more holistic view of the firmwide business and are adept at balancing various risks in achieving tangible outcomes. As a DRI, it is their responsibility to ensure that risks are being appropriately managed, the control function owners voices are being heard while AI initiatives are being implemented. The AI councils tasked with being the gate keepers of all AI initiatives in the firm should report to these leaders. In turn these leaders should report at each board meeting on AI efforts in the firm.

U – Understanding of Risk Appetite and Reporting across the Enterprise

One of the most powerful tools a Board of Directors has in their arsenal is the Risk Appetite statement and supporting Key Risk Indicators (KRI) reporting framework. Risk Appetite statements define the amount and type of risk an organization is willing to accept to achieve its goals and objectives. Good risk appetite statements complement and help achieve strategic goals, are concise, easy to understand and are actionable by management. Bad risk appetite statements on the other hand do the exact opposite, are vague, non-actionable, difficult to measure against. An example of a poorly crafted risk appetite statement is, “We have zero appetite for cyber risk”. While this in principle sounds like a laudable objective, it provides zero guidance to management on how to go about achieving this impossible goal or even measure it.

Typically risk appetite statements are socialized at the Board of Directors and C-Suite level. However, given the emerging nature of AI and associated risks, not all risks can be predicted and known beforehand. Generative AI large language models (LLMs) are especially prone to a “black box” nature where it is sometimes difficult to ascertain the true nature of risks either in the data set used to train the model or the model itself. The firm can put itself at risk due to unexpected risks that materialize due to lack of understanding of what the AI guard rails for the firm are amongst the staff involved in the day-to-day operations. Boards should set expectations of management that the AI risk appetite statement and associated risk metrics are broadly and deeply socialized within the firm, so they are well understood. They can ask for assurances from management that the rank and file of an organization have a clear sense of how AI will be used and adopted in the firm. One particularly effective way to do this is to include the AI risk appetite statement and key KRIs as part of the firm’s mandatory training curriculum for staff.

There are traditionally three types of risk appetite statements based on the maturity of the firm or the specific maturity of a particular risk stripe within the firm. It is not uncommon for a firm to have all three types of risk appetite approaches at the same time based on the years of experience or maturity of a particular area or risk stripe. In fact, best practice indicates multiple risk appetite statements provide a more nuanced understanding of risk and provides more guidance to management

- **High Maturity: Risk appetite focus – “Maintaining Goodness”**

In areas where there is high maturity typically where a firm has years of experience in a particular risk stripe or business area, there should be a mature set of proven KRIs with specified thresholds (Red/Amber/Green) for each KRI and a measurement/reporting regimen in place. This would be supported by a specified set of actions that management would undertake within a specified timeframe to reduce the risk if a breach of a threshold occurs. For instance, if a specific KRI breaches the Amber threshold, there is a specific set of actions that

has been pre-approved that management will immediately start actioning to bring the risk back to green. For breach of red threshold, actions over and above those that occur for amber could include triggering of escalation procedures and reduction in business activity in the areas of concern if required.

- **Moderate Maturity: Risk appetite focus – “Journey to goodness/desired target state”**

In areas where high maturity has not been achieved and there are several multi-year maturity initiatives underway, the risk appetite statement and supporting KRI regimen will be lacking in a full set of proven KRIs, validated thresholds, while the reporting structure may be evolving. In these instances, the risk appetite statements would be a mix of KRIs and “risk burndown” metrics tied to risk reduction/program maturity objectives. One could think about the risk appetite statement in these instances as “The board has zero appetite for the firm not making progress in reducing and maturing risk programs at the expected rate and pace defined by management”. The board in this instance is not reviewing mature KRIs but the risk reduction programs progress in reducing risk. Once the established target state has been achieved, the Board should then pivot to reviewing and challenging a mature set of KRIs and thresholds.

NIST AI RMF Framework is an excellent resource to establish potential risk target states. It introduces the concept of Generative AI profile⁸. An AI RMF current profile once completed would indicate how AI is currently being managed, and related risks in terms of current outcomes. A target profile indicating the outcomes needed to achieve the desired target state AI goals should be established. Comparing current and target profiles reveals gaps to be addressed to meet AI risk management objectives. Risk remediation plans can be developed to address these gaps and an AI risk “burn down” metric can be developed that is tractable to ensure risk reduction is occurring at the expected rate and pace.

- **New and Emerging Risk Areas: Risk appetite focus – “Avoid badness”**

In new and emerging areas, a different approach must be taken, since both mature risk programs/KRIs are lacking as well as there might not be identified risk remediation programs in place. In this case the focus should be on a “guard rails” type of risk appetite statements. Risk appetite statements in this instance focus more on what is out of bounds for the firm “defining what bad looks like” for the firm rather than in the case of a mature program where the risk appetite statements define “what good looks like”.

A good example of this was in the early days of crypto currency. The situation then was a whole host of crypto currencies, NFTs, multitude of crypto exchanges based across the world, pump and dump schemes being the norm. Board Risk Appetite Statements during this period for a conservative US financial institution could be:

- We have zero appetite for the firm dealing in crypto currencies not traded on US crypto exchanges or operating outside of existing emerging regulatory frameworks.
- The firm's exposure to crypto-related activities should be limited to no more than [X]% of our total assets under management or risk-weighted assets with no single crypto currency making up more than [Y]%
- Given our cyber security program has not achieved the desired target state, and given the high risk posed by crypto threat actors, we have zero appetite for accepting any hot or warm crypto wallets.

A similar approach can be adopted by boards for AI, which is a fast-evolving area and in firms which lack a lot of AI expertise or just starting AI adoption. For example, given the recent geopolitical risks, highly regulated firms might consider adopting a metric that protects against this type of risk such as, "we have zero appetite for AI Large Language Models (LLM) developed or sourced from countries X, Y, Z".

KRIs and Reporting

When developing a set of KRIs it is important for these metrics to follow the firm's KRI methodology, risk rating, description and visualization. Typical board members must read and digest over 500 pages per board meeting and anytime metrics are presented that do not follow corporate methodology, can lead to confusion, lack of understanding and waste of precious board time in questioning the metrics. For example, the firm should agree that as far as possible for KRIs shown in percentages, higher percentage is good, low is bad. It is extremely frustrating for board members to do context switching if they do not know for any given metric if high is good or bad. This might mean in some instances firms have to rewire what is being measured and reported on.

In other instances, firms have been guilty of reporting hundreds of metrics with various Red/Amber/Green thresholds to the board. While management might get kudos for being fully transparent with the board and that nothing is being "hidden" from the board, this approach exposes the board to challenge about their level of understanding of the various KRIs, their thresholds and what does it all mean if

some KRIs are green, others amber and some red. Losing the forest for the trees is a real danger for the board in these situations.

We recommend a KRI pyramid concept. Like the stock exchange indices S&P 500, Dow etc., sometimes knowing the direction of travel is sufficient for the board rather than knowing all the intricate details of each metric. Individual indices for various categories based on the adopted framework (e.g. in case of NIST CSF for cyber – Identify/Protect/Detect/Respond/Recover are good categories to adopt for mapping of cyber KRIs) are a good starting point for board reporting. Lower level KPIs, KCIs, and KRIs can all be mapped to these higher-level categories to build a high-level index that is board reportable. Sufficient detail can be provided for each individual index to ensure the board has a good understanding of the underlying risks, causes and direction of travel.

The Board should insist, and this is especially true wrt. an emerging field such as AI where there are several unknowns and rapid advancements are being made daily, that the risk measures cover all the three categories:

- “Known knowns”
- “Epistemic Risk – Known Unknowns” and,
- “Unknown unknowns”

Known Knowns:

These are measures that can be counted/evaluated/captured as part of the AI lifecycle. Boards should ask management to include metrics as part of the standard board reporting that not just focus on risks of AI but also show adoption of AI in the firm. AI is a generational opportunity and firms that do not figure out how to leverage AI and benefit from it will lose out to competitors. Boards should get assurance that management is not too risk averse in adopting AI. Measures such as:

- # of AI initiatives approved by AI Council: Too few could indicate either lack of initiatives being proposed, or AI council requirements are too harsh and unrealistic, both of which could be a problem
- # of AI initiatives in production and live: If a good number of AI council approved initiatives are not live in production this would indicate a different set of problems for the board to consider
- # of AI initiatives live in production that did not go to the AI council: This is a very powerful metric since it gives authority to the AI council. To generate this metric the firm must implement the instrumentation to scan and identify “shadow AI”, determine if they were approved by the AI council and if not, the business entity must explain why it was not in

compliance with corporate policy. In certain instances, for habitual offenders, the business entity head should have to explain to the Board why corporate policy is not being followed.

Epistemic Risk (Known Unknowns):

These fall into two categories, areas where risk is known to exist but cannot be estimated, especially true for Gen AI where it is difficult to estimate the risk given lack of visibility into training data, lack of maturity in AI measurement, wide range of uses, inputs and outputs. The second category is where we do not know if risk occurrence exists or not, because the firm has no visibility or is blind to activities occurring in that domain. Examples may include when traditional network scanners are deployed, they are blind to unknown or unregistered devices, IoT (Internet of Things) or SCADA/PLC systems which are not designed for frequent scanning, air-gapped/isolated systems, serverless functions such as AWS Lambda or short-lived containers etc. In such cases it is more important for the board to question, for example the CISO who is presenting vulnerability stats, not why the vulnerability metric in one month is x% lower, but what assets that can present a security risk are not part of that metric. The greater risk sometimes lies not in what is being measured, but in what is not being measured. The goal for the CISO in this case is to have a measure that shows progress towards reducing these blind spots. Examples of such areas boards can ask management to provide reports/metrics include:

- List of prioritized AI risk areas (link to corporate risk taxonomy) where risk instrumentation does not currently exist to report, estimate, or measure
- Identified blockers (technical know-how, budget, resourcing, contractual, etc.) for getting more visibility and remediation timelines to get required visibility. For hard to mitigate areas, what proxies/compensating controls would be implemented in lieu of full visibility.
- What gives management confidence to continue to operate in these conditions and what early warning triggers have been instituted that will cause us to exit if the risk becomes too high

Unknown Unknowns:

This might seem to be an anomaly. How can a firm act on a risk that is completely unknown? The issue here is the point of view. A particular risk might be completely unknown to a firm, but it could be known to a different firm. This is where ISACs (Industry specific Information Sharing and Analysis Centers), vendor relationships, threat intelligence feeds, industry groups, briefings from AI/cloud security providers, technology/risk blogs, general news feeds help. A firm should be actively involved, scanning these sources to identify new

threats/risks that they were unaware of and update internal processes to account for these new risks if applicable. Examples of such areas boards can ask management to provide reports/metrics include:

- How many new AI specific risks/threats has the firm become aware of in the last quarter?
- Summary report to board on these new AI risks and if they can manifest themselves at the firm?
 - If not, why not? What business conditions need to change for these risks to manifest themselves (e.g. When AI driven output starts getting consumed externally from being solely used for internal purposes) and have our people/process/technology been updated to account for these risks when business conditions change
 - If yes, what changes have been or will be undertaken to people, process, technology to identify/manage/mitigate these risks from occurring. What changes to existing KRIs will occur to measure and account for these new risks?

A – Accelerate continuous learning

We have already acknowledged that AI is a fast-evolving area, bringing in new advancements, risks and solutions at a rapid pace. It is critical that the firm is continuously learning, adapting and implementing changes to its internal processes from these changes. The board has a critical role to play to ensure this happens. Some of the mechanisms that the board can adopt to force management to institutionalize this culture of continuous learning is via summary reporting to the board.

A formal 1–2-page summary writeup from the executives responsible for AI in the firm should be included in every board meeting material. It should cover the following areas:

New Advancements in AI:

This section should highlight any key advancements in AI since the last board report. It should succinctly explain what the specific advancement is, its impact both positive and negative to the firm, and any actions the firm would take as a result.

New AI Risks:

This section should highlight any new AI risks that have surfaced recently and its potential impact on the firm and actions it would require.

Learnings from AI initiatives gone live in the firm:

This section should do a retrospective review of any new AI initiatives gone live since the last board report and summarize lessons learned, if the expected benefits are being achieved, if the controls in place to manage any risks are effective, any new risks that

have surfaced especially in the areas of usage and knowing what management knows now, what would they have changed in the rollout of the AI initiative and how this input is being considered for upcoming AI initiatives.

Another key measure is AI initiatives that will be terminated. Termination could be for a variety of reasons – risks outweigh the benefits, lack of technology maturity, difficulties in hiring appropriate expertise to scale AI initiatives etc. It is important for firms to recognize AI initiatives that are not working out and quickly deploy those resources to those that are working. Often, management continues to drain resources on ineffective programs since they are hesitant to go to the board and admit failure. It is important for the board to help drive a management culture where failure is tolerated and the firm learns to quickly adapt.

Additional metrics that can be considered include the percentage of staff who have taken basic AI training and those with specialized needs specific AI courses geared to them. In fact, just as some risk disciplines such as security, privacy etc. have mandatory training requirements, the board should ask management to make AI training mandatory. Courses should cover how to use AI effectively, how to provide good prompts to get the desired outcomes, possible biases to be aware of, appropriate usage, misuse use cases, human in the loop etc.

R – Respond to Incidents with Structure, Process and Protocols

In spite of best efforts there will be AI incidents. The board should ask management how existing structures and processes to enable incident reporting will be updated to consider AI related incidents. Specifically, what defines an incident as an AI incident? How will it differ from other incidents? Is there clear direction and guidance on how to tag an incident as an AI incident and who has the final authority to confirm? What are the guidelines to set the severity thresholds for AI incidents, what is the severity-based escalation and notification protocol?

What instrumentation and tooling exists to identify AI incidents? Sometimes customers may detect anomalies tied to AI reporting prior to the firm identifying it themselves. What mechanisms exist for customers to promptly report an AI incident? Have the firm's regular channels of reporting of such incidents (chat, phone, emails etc.) been updated to account for AI incidents? Do AI incidents result in a review of testing procedures to identify why it was not found during testing? Do we have a process for identifying root causes for such AI incidents and systematically address them? What are our stats for finding once, fixing many? What are the broad categories of themes that are surfaced as we step back and holistically look at these AI incidents holistically?

Regulations have explicit guidelines on identifying, timeliness and reporting of AI incidents. For instance, the EU AI Act requires serious incidents to be reported within 15 days after the firm has become aware of the incident. Who to report to should also be

carefully considered. In most cases reporting to local regulatory authorities is a requirement and in certain cases, even the public. Sufficient details in the incident report should exist to ensure triage teams can determine which regulatory jurisdictions requirements apply (given that the reporting timelines can vary by regulator) and the associated reporting time-window.

Board members need to understand what types and severity of incidents will be escalated to the board. For those incidents where board notification may be explicitly required, what are the considerations for the board to evaluate. What types and severity of incidents will be tagged as board reportable? In what time-window of the incident occurring will the board be notified?

D – Disclose with Regulatory Readiness

Regulators ultimately hold the board accountable as part of their oversight function to ensure the firm is identifying, assessing and prudently managing AI risks. Therefore, it is imperative not only that the board be well versed in how management is accomplishing those tasks but equally important that they can explain and speak confidently about those efforts to key external stakeholders such as regulators. Often, in the author's experience this is lacking in firms and even though the board may be aware of management actions related to AI, they may fail to articulate them in terms that address the regulator's concerns.

Regulators will have a great line of sight into the AI efforts of all the firms they regulate via regulator interactions, required reporting, exams etc. AI is evolving, and while the regulators may not know everything, their interactions with various firms give them a broader perspective on AI governance best practices than any single firm can have. This puts them in a position where they can identify weak or immature management practices.

The board should ask management to benchmark their AI efforts against other firms in their industries as far as feasible. Regulators are also focused on rigor and type of board challenges to management. Their only view into that are board meeting minutes, presentations and reporting. Hence it is important that the board meeting minutes reflect the quality of debate and level of challenge board members had of management. Often board meeting minutes tend to favor brevity but in areas of challenge it is better for the minutes to be more verbose than brief since it will provide more context and detail to regulators.

Risk acceptance should be another area of interest for boards since regulators tend to focus on that in their interactions with the board. It is understood that in implementing AI there will be risk tradeoffs and some risks will have to be accepted when they are in conflict. The board should have a clear understanding of how management adjudicates between these various risks when they are in conflict and who has decision rights, and

what limits have been put in place to monitor the aggregate risk acceptances across risk stripes, business areas and the firm. For example, often during on-boarding of 3rd party vendors there might be gaps in the security controls of a particular vendor that the security team is not comfortable with, but business might have no options due to lack of alternate vendors, high switching costs, risk may be temporary since the vendor agrees to remediate in a certain timeframe etc. The board should get assurance from management that there is a formal process with sufficient checks and balances with independent control groups to address risk acceptances. This becomes especially true for AI where a lot of risks converge.

Why A.I. GUARD Matters

The A.I. GUARD Framework is more than a checklist; it's a mindset shift for modern boards. By embedding AI oversight into the board's agenda, companies can:

- Protect brand and shareholder value.
- Foster innovation while managing downside risk.
- Demonstrate credibility to regulators, investors, and customers.
- Build long-term trust in AI-enabled products and services.

Conclusion: Boards as Stewards of AI

AI is a strategic risk and is rapidly becoming a key boardroom responsibility. The A.I. GUARD Framework equips boards with the structure and language to lead responsibly in this space. With informed oversight, companies can align innovation, speed to market, enhance competitiveness while ensuring risks are being proactively identified, holistically assessed and prudently managed.

Advancements in AI maturity are now daily occurrences, so Board members need information sources to help them understand the implications for society, industry sectors, customers and employees. Technology choices specific to the deployment of foundation models and RAG inference environments have significant financial implications for the company. Company media management for corporate communications is rapidly changing along with the use of deepfake generative AI impacting the company's brand in the marketplace. The A.I. GUARD Framework helps to guide board members to deal with the rapid evolution of generative AI and the impact on the enterprise.

APPENDIX A: TEMPLATE FOR BOARD AI REPORTING

The authors have created a draft template highlighting the key areas of the A.I. Guard principles that a board should be focused on. Practitioners can leverage this template and customize it to their specific needs which might include alignment with the rest of the report formats, reporting styles, rating schemes etc. This template focuses on standard periodic reporting elements. One-off elements such as AI risk taxonomy, AI framework adoption and associated rationale, key AI board speaking notes etc. are not part of this template. For ease of understanding and brevity, this template identifies only a few of the elements that should be in a standard report for each section. Practitioners should refer to the relevant sections in this paper for a more detailed list of elements to include.

Section 1: Key Firmwide AI Initiatives Update

Format: 1 paragraph for each initiative written in narrative style in plain English summarizing what the initiative is, goals/benefits, status, risks/issues, go forward plan and key learnings

The leaders accountable for the AI initiatives in the firm should highlight 2-3 material AI initiatives for the board. It is recommended they choose different initiatives to highlight for each board meeting.

Section 2: Key External AI Events and Associated Learnings

Format: 2-3 sentences about each external AI material event.

Highlight top 5 external AI events since the past board meeting. Discuss why the events were material, potential impact to the firm and its on-going AI initiatives. Highlight any new risks that have risen due to this new event and how the firm intends to address it

Section 3: Risk Appetite and Risk Reporting

Format: Leverage firm specific risk taxonomy and risk reporting format/style. If a particular framework such as NIST AI RMF is chosen, risk reporting should align with the broad categories of NIST.

Risk report that shows the key AI specific risk appetite metrics and current values for high maturity KRIs. For moderate maturity risk measures show if on-going risk mitigation measures are on track and if the expected risk burndown is being achieved. Highlight any deviations from the expected path, associated reasons, and path to get back to track. For new and emerging risk areas, reiterate the “avoid badness” risk appetite statements and identify any drivers if applicable that might necessitate a revisit of the statements. For epistemic risk areas

“known unknowns” list prioritized risk areas, identified blockers for getting more visibility along with remediation timelines and any exit criteria. Risk Acceptance metrics and general areas where risks are being accepted should be presented and discussed along with any breach of risk acceptance thresholds.

Section 4: Continuous AI Learnings

Format: Specific metrics on general staff training and any specialized training for advanced courses.

List 3-4 learning metrics, status against thresholds, training effectiveness stats. Any additional new AI risk learnings that were not covered in section 2 either internally or externally can be covered in this section

Section 5: Incident Response

Format: List the AI incident, materiality, root cause, who got notified, potential regulatory impact and actions taken

List top 5 material AI incidents and discuss potential impact, controls that failed, status of remediation efforts. For incidents that require regulatory notifications, list regulators notified, any feedback received from regulators. Also discuss what actions the firm is taking in the “find once, fix many” mindset to ensure there are no-repeats of the root causes.

References

1. This example came from Shelly Palmer, <https://shellypalmer.com/>
2. Public_Groq_llama-3.1-8b-instant_8192, May 18,2025
3. <https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-state-of-ai>
4. <https://www.ibm.com/thought-leadership/institute-business-value/en-us/report/2025-banking-financial-markets-outlook>
5. <https://fortune.com/2025/05/09/ceos-fear-losing-jobs-ai-survey/>
6. <https://nanda.media.mit.edu/>
7. <https://www.nacdonline.org/all-governance/governance-resources/governance-research/director-faqs-and-essentials/implementing-ai-governance/>
8. <https://www.nist.gov/itl/ai-risk-management-framework>
9. <https://www.pdpc.gov.sg/-/media/Files/PDPC/PDF-Files/Resource-for-Organisation/AI/SGModelAIGovFramework2.pdf>
10. <https://artificialintelligenceact.eu/>
11. <https://saif.google/>
12. <https://www.microsoft.com/en-us/ai/principles-and-approach>
13. <https://www.gartner.com/en/information-technology/glossary/ai-trism>
14. <https://www.iso.org/standard/42001>